

RESEARCH NOTES / EPISODE 01

Can cybersecurity keep pace with modern digital risk?

A 2026 reappraisal of my A-level EPQ: "An investigation into Cyber Security and whether it is secure for modern-day use?"

Nathan Brown-Bennett

Revised research edition · July 2026

Original A-level submission: 2020

This is a new critical edition, not a retrospective alteration of the assessed A-level submission. The original is preserved separately. Claims, evidence and references in this edition were re-evaluated in 2026.

Abstract

My original EPQ asked whether cybersecurity itself was “secure” enough for modern use. That wording captured a genuine concern but treated security as a binary property: either a system is safe or it has failed. This revised paper reframes the question as whether contemporary cybersecurity can reduce, govern and recover from digital risk at the pace at which that risk changes. It revisits the original themes—definitions, public understanding, human behaviour, automation, regulation and education—using evidence available in 2026.

The evidence shows a difficult but more useful answer. Threat volume and consequence remain high: 43% of UK businesses identified a breach or attack in the 2025/2026 survey, while the National Cyber Security Centre handled 204 nationally significant incidents during 2024–25. Yet successful defence is often invisible, and the existence of incidents does not demonstrate that cybersecurity is ineffective. Effectiveness is better judged through risk ownership, secure-by-design engineering, usable defaults, detection, response and recovery. The central conclusion is that cybersecurity can keep pace only when it is treated as a continuous socio-technical capability rather than a product, a one-off control, or a demand that individual users never make mistakes.

Research integrity and provenance

The historical source is the 22-page Word document submitted for my A-level Extended Project Qualification. Two copies supplied for this revision were byte-for-byte identical. A PDF supplied alongside them contained only one rendered page and is therefore not a complete archival copy. The portfolio previously linked to a different planning document about PC security and practicality; this edition corrects that mismatch.

WHAT HAS AND HAS NOT BEEN CHANGED

This edition preserves the original intellectual starting point but rewrites the argument, replaces weak or stale web references with authoritative and current material, and adds explicit limitations. No new participant study has been conducted. The original small Google Forms exercise is discussed only as historical evidence of how the project was developed; it is not presented as representative research.

Report structure

1. Part I — Define the field and repair the research question
2. Part II — Test the argument against current evidence
3. Part III — Explain what effective practice requires
4. Part IV — Trace the research into a product direction

PART I

Define the field

The terminology matters because each field protects a different boundary and answers a different operational question.

1. What security means

Security is the managed reduction of unacceptable harm. It is not the promise that nothing bad can happen. A security decision identifies something of value, the threats and

weaknesses that could affect it, the likely consequence, and the controls proportionate to that risk.

Four properties recur across the security fields: confidentiality—preventing unauthorised disclosure; integrity—preventing unauthorised or accidental change; availability—keeping authorised access and essential service; and resilience—containing disruption and restoring trusted operation. Authenticity, accountability, safety and privacy may also matter depending on the system.

A PRACTICAL TEST

What are we protecting? From which harm? Who owns the decision? Which control reduces the risk? How will we know it works? What happens when it fails?

2. Why the original question needed reframing

The phrase “whether cybersecurity is secure” sounds intuitive, but it combines two different ideas. Cybersecurity is the collection of people, processes, technologies and decisions used to manage digital risk. A particular system can be more or less resistant to known threats; the discipline used to protect it cannot meaningfully be certified as permanently “secure”. The original question therefore risked judging an adaptive practice against an impossible condition.

The original paper used the history of locks to contrast “perfect security” with modern defensive practice. That analogy remains useful if its lesson is stated carefully: a lock is not worthless because it can eventually be picked, and a cyber control is not ineffective because a sufficiently capable adversary might bypass it. Security is contextual. It depends on what is being protected, from whom, for how long, at what cost and with what consequence if the control fails.

This is consistent with modern frameworks. NIST’s Cybersecurity Framework 2.0 describes outcomes for governing, identifying, protecting, detecting, responding and recovering from cyber risk (Pascoe, Quinn and Scarfone, 2024). The addition of “Govern” is especially important. Security is not simply an IT team’s defensive activity; it is a management decision about priorities, responsibilities, dependencies and acceptable risk.

REVISED RESEARCH QUESTION

Can contemporary cybersecurity reduce and govern digital risk—and help organisations recover—at the pace at which technology, dependency and adversarial capability change?

3. What each security field handles

These terms overlap, but they are not synonyms. A useful distinction begins with the object being protected and the boundary within which the work is performed.

Computer security. Protects an individual computing system—its operating system, software, memory, storage and local data. Typical controls include patching, secure boot, malware protection, access control and hardening. Example: preventing unauthorised code from gaining administrator access on a laptop.

IT security. Protects an organisation’s technology estate and the services it operates: devices, servers, networks, applications, identities, cloud platforms and backups. Typical controls include

asset management, network segmentation, identity administration, monitoring and recovery. Example: ensuring staff accounts and managed devices can use a business system safely.

Information security. Protects information in any form—digital, paper or spoken—against loss of confidentiality, integrity or availability. It is broader than technology. Example: controlling who may view a printed personnel file as well as its digital copy.

Cybersecurity. Manages harm arising through connected digital systems. It includes technology and information, but can also protect people, services, organisations and physical processes reachable through cyberspace. Example: preventing a compromised connected device from disrupting a service or exposing its users.

In practice, one incident can cross all four boundaries. A vulnerable laptop is a computer-security problem; weak enterprise account management is an IT-security problem; exposed records are an information-security problem; and the connected attack path and resulting harm are a cybersecurity problem.

3.1 Typical roles and deliverables

Computer security. Endpoint or platform security engineer; operating-system specialist; malware analyst. Outputs: hardened builds, patch baselines, endpoint controls and technical findings.

IT security. Security analyst; identity and access specialist; network or cloud security engineer; security administrator. Outputs: managed access, architecture, monitoring, backup and operational control.

Information security. Information-security manager; risk and compliance specialist; security governance lead; information asset owner. Outputs: classification, risk treatment, policy, assurance and audit evidence.

Cybersecurity. SOC analyst; incident responder; threat-intelligence analyst; penetration tester; application-security engineer; security architect. Outputs: threat-led defence, detection, incident containment, testing and recovery improvement.

Job titles are not standardised. A small organisation may combine all of these duties in one IT role; a large organisation may split one duty across several teams. Scope, authority and evidence are more reliable than the title alone.

3.2 Where the fields overlap

- Identity and access control crosses computer, IT, information and cyber security.
- Patching begins as computer or platform security, becomes an IT deployment process, and reduces a cyber attack path.
- Logging is configured by technical teams, monitored by security operations, and retained as information and audit evidence.
- Incident response joins technical containment, business continuity, information assessment, legal duties and external communication.
- Secure product development combines computer security, application security, information protection and threat-led cybersecurity.

3.3 One incident, four perspectives

Consider a staff laptop compromised through a stolen cloud credential. Computer security asks whether the endpoint was patched, hardened and able to isolate malicious activity. IT security asks how the identity, device, network and cloud service were administered and monitored. Information security

identifies which records were exposed, their sensitivity and the organisation's obligations. Cybersecurity reconstructs the connected attack path, contains the adversary, assesses wider harm and improves detection and resilience.

The fields therefore overlap by design. Clear handoffs prevent gaps: the endpoint team supplies evidence; IT revokes access and restores service; information owners assess impact; incident responders coordinate containment and lessons learned; leadership accepts or funds the remaining risk.

3.4 The academic boundary

Von Solms and van Niekerk argue that cybersecurity extends beyond traditional information assets to people and other assets reachable through cyberspace (2013). That distinction is useful, but organisational teams still share controls and responsibilities. The labels should clarify ownership—not create silos.

3.5 Resilience changes the test

A prevention-only definition creates a misleading pass/fail test. Modern services depend on cloud platforms, identity providers, software libraries, suppliers, connected devices and human decisions. Some failures will occur even in mature environments. Resilience asks the harder questions: Was the most likely harm reduced? Was abnormal activity detected? Could the organisation isolate the problem? Were essential services maintained? Could trustworthy operations be restored and lessons applied?

The NCSC's 2025 Annual Review makes this distinction directly. The agency reported that attackers were improving their ability to cause impact, but also observed that many more attacks fail than succeed and that prepared organisations are better able to continue operating when an attack gets through (NCSC, 2025a). This means incident counts should inform urgency, not serve as a simple score of whether cybersecurity "works".

4. What the original project got right

The A-level paper was written with limited access to academic databases and before several now-central UK policy changes. Even so, four instincts have survived scrutiny.

- Perfect security is not a useful operational goal. Defenders need continuous learning, layered controls and recovery.
- Public understanding matters. Security decisions fail when advice is incomprehensible, unaffordable or detached from how people actually work.
- Automation is necessary at scale. Machines can process telemetry and repeat controls more consistently than manual work alone.
- Cybersecurity connects technology with governance, education and society. It cannot be reduced to antivirus software or a specialist team.

The original participant exercise also revealed a worthwhile design question: people can feel confident about common cyber terms while interpreting them differently. However, the study's sample was small and socially concentrated, the document reports both 20 and 25 responses in different places, and one question assumed a universal minimum password length that does not exist. The finding is therefore a prompt for further research, not evidence about the general population.

PART II

Test the argument

Current evidence shows high exposure, rising consequence and a persistent gap between available practice and consistent adoption.

5. What has changed since 2020

5.1 Digital dependency became operational dependency

The years following the original submission made digital dependency more visible. Remote work, cloud services, software-as-a-service, connected devices and complex supply chains increased the number of systems that organisations must trust. Cyber harm is no longer confined to lost files: incidents can interrupt retail, manufacturing, healthcare, education, logistics and public services.

ENISA analysed 4,875 incidents between July 2024 and June 2025 for its 2025 Threat Landscape, illustrating both the scale and diversity of the European threat environment (ENISA, 2025). In the UK, the NCSC handled 429 incidents in 2024–25, of which 204 were nationally significant and 18 highly significant. The number of nationally significant incidents was more than double the previous year's 89, although reporting and categorisation data must not be treated as a complete census (NCSC, 2025b).

5.2 Security expectations moved towards products and leadership

Responsibility has begun to move upstream. The UK's consumer connectable product security regime came into effect on 29 April 2024, placing minimum security obligations on manufacturers and supply-chain businesses for relevant smart products (DSIT, 2024). The UK Cyber Governance Code of Practice, launched in 2025, similarly frames cyber risk as a board responsibility tied to operational and financial viability (DSIT and NCSC, 2025).

For software, secure-by-design guidance now asks vendors to threat-model early, enforce strong authentication for privileged users, remove default passwords, validate input, protect credentials and plan for secure updates (NCSC, 2025c). This is a decisive shift from telling end users to compensate for unsafe products.

6. What current evidence says about effectiveness

43% UK businesses identifying a breach or attack in the preceding 12 months. *DSIT & Home Office, 2026*

204 nationally significant incidents handled by the NCSC in 2024–25. *NCSC, 2025*

30% businesses conducting a cyber-risk assessment. *DSIT & Home Office, 2026*

25% businesses with a formal incident-response plan. *DSIT & Home Office, 2026*

Interpretation: attack prevalence measures exposure and detection, not the absence of defensive value. The more revealing gap is between recognising cyber risk and consistently governing, testing and recovering from it.

6.1 Exposure remains widespread

The Cyber Security Breaches Survey 2025/2026 estimates that 43% of UK businesses and 28% of charities identified a breach or attack in the previous 12 months. Medium and large businesses reported higher prevalence than micro businesses, partly because they present larger targets and often have stronger detection capability (DSIT and Home Office, 2026). The survey explicitly warns that unidentified or undisclosed incidents mean the true prevalence may be higher.

Phishing remained the dominant cyber-crime category among organisations reporting cyber crime. Yet the same survey found that most organisations affected by their most disruptive breach restored operations within 24 hours. Those facts can coexist: exposure can be frequent while many incidents are contained. A mature assessment must measure severity, duration, recovery and avoided harm—not just whether an attempt occurred.

6.2 Governance and preparedness are inconsistent

The more concerning figures describe preparation. Only 30% of businesses reported conducting a cyber-risk assessment, 31% assigned explicit board responsibility, and 25% had a formal incident-response plan. Forty-five per cent of businesses reported none of the listed incident-response measures. Even where plans existed, qualitative interviews suggested that some had never been tested (DSIT and Home Office, 2026).

This gap supports a revised conclusion: the limiting factor is not that cybersecurity as a discipline has no effective practices. It is that proven practices are unevenly adopted, poorly integrated with business decisions, or left untested until a crisis.

PART III

Explain effective practice

Security works when products, organisations and people share responsibility through usable controls, evidence and tested recovery.

7. People, usability and responsibility

7.1 “Human error” is an incomplete diagnosis

The original paper described employees as a major weakness and suggested that fear of mistakes could encourage organisations to replace people with automation. That framing now seems too blunt. A person may click a convincing message, reuse a password, postpone an update or work around a control; but those actions occur inside systems designed by organisations. If a single ordinary mistake can create catastrophic harm, the architecture, defaults, permissions, recovery process and organisational incentives also require scrutiny.

Security guidance that imposes unlimited effort on users can be economically irrational from their perspective. Herley's analysis of security advice argued that users bear the cost of precautions while many benefits are diffuse or invisible (2009). Usable security research likewise shows that controls must fit human capability and real tasks. The goal is not to eliminate human agency but to make the safe path comprehensible, convenient and forgiving.

DESIGN IMPLICATION

Treat mistakes as signals. Reduce privilege, provide phishing-resistant authentication, make reporting safe, isolate failures, log decisions, and design recovery so one action does not become an organisational disaster.

7.2 Education still matters—but it is not a substitute for design

The original project was right to value cyber education. Training helps people recognise suspicious behaviour, understand reporting routes and make informed choices. But awareness campaigns cannot repair insecure defaults, unsupported devices, unclear interfaces or absent leadership. Training must sit beside technical controls, clear ownership and a culture in which early reporting is rewarded rather than punished.

8. Automation and artificial intelligence

8.1 Automation is indispensable, not autonomous

Automated asset discovery, configuration checking, telemetry analysis and response orchestration allow defenders to operate at a scale that manual work cannot match. However, automation reproduces its assumptions. Poor rules can block legitimate work, miss novel behaviour or create a false sense of control. Good systems therefore preserve auditability, allow proportionate human review and are tested against realistic failure modes.

8.2 AI changes both attack and defence

The original paper presented AI primarily as a faster detector and asked whether it might replace cybersecurity staff. The 2026 position is more complex. AI can assist triage, anomaly detection, code analysis, summarisation and threat intelligence. It can also help attackers scale convincing content, search for weaknesses and automate parts of an intrusion. AI systems introduce their own risks through training data, model behaviour, integrations, access to sensitive information and over-trust in outputs.

NIST's AI Risk Management Framework organises responsible practice around governing, mapping, measuring and managing AI risk across the lifecycle (NIST, 2023; 2024). NCSC guidance similarly applies secure design, threat modelling, logging and incident management to machine-learning systems. The appropriate conclusion is not people versus machines. It is that accountable professionals should use automation while retaining judgement over context, consequence and exception.

9. What effective cybersecurity looks like

A useful model combines the six NIST CSF 2.0 functions with secure-by-design practice. The functions are not a maturity score or a one-time sequence; together they provide a way to ask whether an organisation can make and sustain good risk decisions.

Govern. Who owns the risk and sets priorities? Evidence: Named responsibility, policy, risk appetite, supplier oversight.

Identify. What do we depend on and what could go wrong? Evidence: Asset inventory, dependency map, risk assessment, threat model.

Protect. How is likely harm made harder? Evidence: Secure defaults, MFA, least privilege, patching, backups, segmentation.

Detect. How would we know something changed? Evidence: Useful logs, monitoring, tested alerts, reporting routes.

Respond. Can we contain and communicate? Evidence: Rehearsed roles, isolation, decision logs, regulator and supplier routes.

Recover. Can trusted service be restored? Evidence: Tested backups, recovery objectives, learning review, improvement tracking.

A control should also be judged by whether people can use it correctly, whether failure is contained, and whether the organisation can demonstrate that it works.

PART IV

Turn research into a product direction

The work moves from a broad security question to a concrete tool for making device decisions clearer, safer and auditable.

10. From research to a product direction

The most durable question in the original EPQ was practical: how can security guidance reach the person making a real decision? My later undergraduate dissertation, "How do we decide what we provide?", narrowed that broad concern to device procurement and provisioning. It examined how people choose connected devices, how security evidence can be compared, and how configuration advice can be turned into an operational process.

That work led to the Device Provisioning Toolkit: a research prototype that discovers devices, compares relevant security signals and generates a tailored hardening guide. The product direction reflects the revised thesis of this paper. It does not promise perfect security. It tries to make a safer decision easier, document the reasoning, reduce insecure defaults and support repeatable action.

RESEARCH-TO-PRODUCT THREAD

EPQ: security is never finished → undergraduate research: device choices need clearer evidence → product prototype: turn security evidence into a usable, auditable provisioning workflow.

11. Limitations

- The revised edition is a critical literature-based reappraisal, not a new empirical dissertation.
- The original Google Forms exercise cannot support population-level claims because of its size, recruitment method and inconsistent reported response counts.
- Official incident and survey statistics measure different populations and depend on detection and reporting; they should not be combined as if they were one dataset.

- The threat landscape changes quickly. Evidence is current to July 2026, but figures and guidance should be rechecked before later publication or recording.
- The Device Provisioning Toolkit is a research prototype. Retailer data, public vulnerability information and generated guidance can be incomplete and require review.

Conclusion

Cybersecurity cannot make modern digital life permanently free from danger, and describing it as either secure or insecure obscures the decisions that matter. The more defensible question is whether our institutions and products reduce likely harm, recognise failure, contain its consequences and recover in a trustworthy way.

Current evidence shows both pressure and possibility. UK organisations continue to experience frequent attacks and nationally significant incidents have risen sharply. At the same time, authoritative frameworks describe practical controls, many attacks fail, and prepared organisations recover more effectively. The persistent weakness is implementation: too few organisations conduct risk assessments, assign board responsibility or maintain tested response plans.

My answer in 2026 is therefore conditional. Contemporary cybersecurity can keep pace, but only when it is continuous, governed, usable and designed into products and services. Education and automation remain necessary, yet neither can carry responsibility alone. The best security makes the safer action easier, limits the cost of mistakes and turns evidence into decisions people can act on.

References

- CISA (2025). [Product Security Bad Practices \(updated guidance\)](#).
- Department for Science, Innovation and Technology (DSIT) (2024). [The UK Product Security and Telecommunications Infrastructure \(Product Security\) regime](#).
- DSIT and Home Office (2026). [Cyber Security Breaches Survey 2025/2026](#).
- DSIT and National Cyber Security Centre (NCSC) (2025). [Cyber Governance Code of Practice](#).
- European Union Agency for Cybersecurity (ENISA) (2025). [ENISA Threat Landscape 2025](#).
- Herley, C. (2009). [So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users](#).
- NCSC (2018). [Secure by Default](#).
- NCSC (2025a). [Annual Review 2025 launch](#).
- NCSC (2025b). [NCSC Annual Review 2025: Incident management](#).
- NCSC (2025c). [Software Security Code of Practice: Secure design and development](#).
- NIST (2023). [Artificial Intelligence Risk Management Framework \(AI RMF 1.0\)](#).
- NIST (2024). [Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile](#).
- Pascoe, C., Quinn, S. and Scarfone, K. (2024). [The NIST Cybersecurity Framework \(CSF\) 2.0](#).
- Verizon (2025). [2025 Data Breach Investigations Report](#).

von Solms, R. and van Niekerk, J. (2013). [From information security to cyber security. Computers & Security, 38, 97–102](#).

Reference review date: 19 July 2026. Web links are included for transparency; access dates should be refreshed if the work is submitted or republished later.

Appendix A. Revision at a glance

Question: Binary security test → Continuous risk and resilience test.

Evidence: Mixed web sources → Current official, standards and peer-reviewed sources.

People: Primary weakness → Participants in a designed system.

AI: Possible replacement → Governed support for accountable professionals.

Outcome: Awareness as the answer → Secure design, governance, usable controls and recovery.